

Politecnico di Torino

Master's Degree in Cybersecurity

Lecture Notes of Information Systems Security (01TYMUV, 01TYMUW)

Author:
Marco Smorti
Riccardo Zaccone
Giovanni Nicosia

Professor:
Prof. Antonio Lioy

Academic Year: 2023/2024

Last update: February 2024

Contents

I Theory **3**

II Social Engineering **4**

9 Social engineering: a sociological perspective **5**

9.1 Introduction . . . 5
9.2 Definitions: cybersecurity and social engineering . . . 6
9.2.1 Cybersecurity . . . 6
9.2.2 Social engineering . . . 6
9.3 Requests and actionability . . . 7
9.3.1 The request as the starting point . . . 7
9.3.2 What makes a request actionable . . . 7
9.3.3 The role of technical design . . . 7
9.4 Context: the frame of an event . . . 8
9.4.1 Definition . . . 8
9.4.2 Why a frame is necessary . . . 8
9.4.3 Context in a simple request . . . 8
9.4.4 Context as a tool of the attacker . . . 8
9.4.5 Solidity instead of truth . . . 9
9.5 Communicating is acting . . . 9
9.5.1 Words that produce facts . . . 9
9.5.2 The temperature of a message . . . 9
9.6 The formal record: $R = (q, C, a)$ . . . 9
9.6.1 From narrative to record . . . 9
9.6.2 Using the record well . . . 10
9.7 Reconstructing an incident . . . 10
9.7.1 Three stages of the method . . . 10
9.7.2 Reported events and explanations . . . 11
9.7.3 Sources and their position . . . 11
9.7.4 Explanations are provisional . . . 11
9.7.5 A story that does not need to justify itself . . . 11
9.7.6 Question marks are part of the model . . . 12
9.7.7 Investigations end, and restart . . . 12
9.7.8 Recommendations come last . . . 12
9.8 Status, role and authority . . . 12
9.8.1 Status and role . . . 12
9.8.2 Authority . . . 13
9.8.3 Claimed, actual and attributed positions . . . 13
9.9 Expectations and social norms . . . 14
9.9.1 Empirical and normative expectations . . . 14

9.9.2 Social norms . . . 14
9.9.3 Separating norms from observed behaviour . . . 14
9.10 The definition of the situation . . . 15
9.11 Case A: the confidential acquisition . . . 16
9.11.1 Exercise on Case A . . . 16
9.11.2 Variations on Case A . . . 17
9.12 Case B: the institutional mailbox . . . 17
9.13 Three constants of social engineering . . . 17
9.13.1 Epistemic asymmetry . . . 18
9.13.2 Technocratic dominance . . . 18
9.13.3 Teleological replacement . . . 19
9.14 Recordings and the epistemic backstop . . . 19
9.14.1 From speech to recording . . . 19
9.14.2 Knowledge we do not check ourselves . . . 20
9.14.3 The backstop as deterrent . . . 20
9.14.4 The regulatory function . . . 20
9.14.5 A recording as corrector . . . 21
9.15 Contested evidence . . . 21
9.15.1 Seeing is believing? . . . 21
9.15.2 When even genuine evidence loses weight . . . 21
9.15.3 A shared alphabet of method . . . 22
9.16 Case A revisited: sources, requests and records . . . 22
9.16.1 The voice as a source . . . 22
9.16.2 A recording produced later . . . 22
9.16.3 Evidence and proposition . . . 22
9.16.4 Attribution and mandate . . . 23
9.16.5 Keeping the actor and the moment . . . 23
9.16.6 Two recipients, different records . . . 23
9.16.7 The executed transfer . . . 23
9.16.8 Two hypotheses about the destination . . . 24
9.16.9 From two premises to a conditional conclusion . . . 24
9.16.10 Purpose is not a hidden equality . . . 24
9.17 Communicating an analysis in progress . . . 24
9.18 Influence: why some requests are accepted . . . 25
9.18.1 Reciprocity . . . 25
9.18.2 Commitment and consistency . . . 26
9.18.3 Social proof . . . 26
9.18.4 Authority . . . 26
9.18.5 Liking . . . 27
9.18.6 Unity . . . 27
9.18.7 Scarcity . . . 28
9.19 Summary . . . 30

III Exercises without solutions **32**

IV Exercises **33**

Part I

Theory

Part II

Social Engineering

Chapter 9

Social engineering: a sociological perspective

9.1 Introduction

Most security incidents involve people. An attacker who wants to obtain money, data or access does not always need to break a cryptographic algorithm or find a flaw in a program: it is often enough to obtain the cooperation of someone who has the authority to act. This is the core of *social engineering*: the manipulation of human interactions in order to make a person perform an action that serves the attacker.

The technical literature usually describes social engineering attacks through their channels (email, telephone, messaging) and through their tricks (fake identities, urgency, impersonation). This chapter adopts a complementary point of view. It asks how a request becomes something that a recipient can interpret and act upon, which relationships give it weight, and which conditions made the response plausible at the time. This is the approach of sociology: to explain actions by looking at the positions of the people involved, the expectations they hold, the rules they follow and the situation as they understand it.

The sociological perspective does not replace the technical analysis. A technical account explains the channel and the operation with precision; a sociological account explains why the operation worked on the person who received it. A complete analysis of a social engineering incident needs both, and the second is the one that makes the first useful for prevention.

The aim is a better interpretation of an incident than the ones produced by stereotypes, prejudice, common sense or ignorance. Disagreements about what someone said are common. A person may deny having made a statement and claim that the story was invented, with no witnesses to confirm it, and a single word is rarely enough to settle the matter.

Organisation of the module

The part of the course devoted to social engineering is evaluated through two open questions, each marked out of 10. The result contributes one quarter of the final grade of the Information Systems Security course. In an answer, naming a concept is not sufficient: one has to explain what the concept makes visible in the case under discussion, and which details of the case support the explanation. A different interpretation of a case is acceptable, provided it is defended from the available evidence.

A method for the reader

The chapter follows the order in which the concepts are needed. It starts from the request, then introduces the notion of context, the formal record used to organise an incident, the concepts of status, role and authority, the notions of expectation and social norm, and the idea of the definition of the situation. Two cases are then reconstructed using these tools. The chapter ends with the principles of influence that explain why some requests are accepted more easily than others.

Each concept is introduced through an example from everyday university life before it is applied to a security case. The aim is not to memorise labels, but to be able to recognise each concept in a new situation and to use it to make an explanation more precise.

9.2 Definitions: cybersecurity and social engineering

9.2.1 Cybersecurity

A useful definition of cybersecurity is the one proposed by Craigen, Diakun-Thibault and Purse (2014): cybersecurity is the organisation and collection of resources, processes and structures used to protect cyberspace and cyberspace-enabled systems from occurrences that misalign *de jure* from *de facto* property rights. The definition is dense, but each of its parts can be read in the analysis.

Cybersecurity is first of all an activity: it consists of organising, that is, designing and doing. The same holds for social engineering understood as communication: it is doing something by saying something. The resources include money, hardware and software, but also symbolic resources such as relationships, emotions and expectations. The processes are interactions among positions in a network, governed by roles and norms. Routines that repeat over time become institutionalised and transparent, and people perform them on autopilot. The structures are pillars at different scales, as organs are for a body: a seat is part of a room, a room is part of a university, and a university is part of a larger network. Some organs are vital and others only partly necessary; the analysis asks which structure a given attack reaches.

Cyberspace is the network of machines, people and software connected into a network of networks. What defines a cybersecurity system is its aim, which is to protect something. Cyberspace-enabled systems now include household appliances, locks, lights and cars. A "fridge crisis" reported in the United States and France, believed to be a cyber attack, is cited as an example that even household appliances are now exposed. As more artefacts are connected, the set of elements, responsibilities and risks that cybersecurity must consider grows. The question of who is accountable when an autonomous car harms a pedestrian is a cybersecurity question as much as a legal one.

Finally, the definition distinguishes *de jure* from *de facto* rights. A person may be recognised by law or by society as the legitimate owner of a digital asset and yet be unable to control it or use it as they could. Cybercrime is the set of phenomena that make these two things diverge. The analytical question is always where they come apart.

Game theory helps here. In Case A the sum is zero: money taken from one account is added to another, so the total stays the same. With digital assets the sum can be positive. Copying data does not remove it from the original dataset, so the owner keeps it, and the attacker gains access that should not exist. Sometimes a cyber attack does not require a zero-sum situation.

9.2.2 Social engineering

Wang, Sun and Zhu (2020) define social engineering in cybersecurity as a type of attack in which the attacker or attackers exploit human vulnerabilities through social interaction in order to breach cybersecurity. Social engineering is therefore a subset of the issues studied in cybersecurity. What

distinguishes it is the human variable: it exploits human vulnerabilities, or some characteristics of human and social interaction, rather than a technical flaw alone.

The term was not born in cybersecurity. Its economic and political-social uses came first, and the history of the origin of these attacks is treated as a separate part of the material. It is a story rather than a technical argument, and it should be known in one's own words rather than learned by heart.

9.3 Requests and actionability

9.3.1 The request as the starting point

A social engineering incident typically begins with a *request*: someone asks another person to provide information, to arrange a payment or to allow access to a resource. A technical description can tell us a great deal about the channel used and the operation performed. It tells us much less about how the request became something the recipient could interpret and act upon.

The same words can carry very different implications. A message asking for a document from a project partner, and the same message coming from the person responsible for assessing the project, are identical as text. The difference lies in the relationship between the sender and the recipient, and in what each relationship makes expected. The relationship changes what is at stake in responding, and therefore changes what a reasonable response is.

9.3.2 What makes a request actionable

A request becomes actionable when several conditions hold together. Someone must recognise the task. Someone must decide who is responsible for it. And there must be a way to proceed. Organisations have rules, practices and procedures that provide these conditions: a request may fit an established procedure, or it may invoke an exception to it. A security problem often concerns exactly this fit, and the question of who has the authority to decide what happens when people are uncertain.

Consider a shared project folder. The software makes collaboration easy, but someone must still decide who can open the folder, who can change its files and who can invite other people. Now imagine a message asking to add a new person to the folder urgently. To understand the response, it is not enough to know which button was pressed. We need to know who is asking, whether this person is entitled to ask, whether there is a procedure or a colleague against which the request can be checked, and whether there is a pressure, formal or informal, to act quickly. These questions are about the organisation, not about the software, even though the software is where the action takes place.

9.3.3 The role of technical design

Technical design participates in these conditions. An interface can display an institutional identity, permit a transfer or require a particular confirmation. It can make some information immediately visible and leave other information elsewhere. But what a person does with an interface depends on the conditions under which it is used: the pressure of the moment, the expectations of the organisation and the information the person has. Understanding the behaviour of a person in front of an interface therefore requires studying the conditions of use, which is a different activity from studying the technology itself.

9.4 Context: the frame of an event

9.4.1 Definition

The central concept of the sociological toolbox is *context*. Context is the frame that surrounds an event, separating what belongs to the event from what lies outside it, and supplying the information needed to interpret the event. A useful image is that of a painting: the frame is not the subject of the picture, but it determines where the picture begins and ends, and it tells the viewer how to read what is inside it. In human interactions the frame is mostly symbolic. We do not touch it, but we understand it, because we have been socialised to the norms that mark the boundaries of an interaction.

The idea goes back to the work of the sociologist Erving Goffman, who used the notion of frame to describe how people understand what is taking place around them. For the purposes of this chapter, a context is a set of elements that makes an event interpretable: the people involved, the channel used, the positions they hold, the earlier exchanges, the place and the timing of the interaction.

9.4.2 Why a frame is necessary

Reality is a continuous flow. No person can receive and process every piece of information present in a situation, so people simplify. They decide, often without noticing, which elements belong to the situation and which do not. A frame makes this simplification possible, and it is also what makes the simplification fallible: whatever lies outside the frame is not considered, even when it is relevant.

The same logic applies to communication. The Shannon–Weaver model, one of the first technological models of communication, describes a source, a message, a channel and a receiver. In human interaction the elements are the same, but a further variable complicates them: the receiver interprets the message according to a frame, and different receivers can build different frames for the same message. This human variable is what makes social engineering possible.

9.4.3 Context in a simple request

Take the message *"can you send it today?"* On its own, the sentence leaves almost everything open. What is *it*? Why does *today* matter? Who is asking? Normally we answer these questions automatically, through the routines of everyday life. Routines are useful because they spare us from questioning every event, but they also hide the assumptions on which we rely.

Now add some context. An earlier message identifies a draft report. The sender is the person who is compiling it. A deadline explains why today matters. The words are the same, but the sentence has become interpretable, because the resources for making sense of it are now available. If the same words came instead from an unfamiliar account, with no earlier exchange, the resources would be different, and the interpretation would change with them.

9.4.4 Context as a tool of the attacker

In social engineering, the context is often built on purpose. The attacker does not simply send a request; the attacker prepares the frame in which the request will be read. The most common technique is to *announce* what will happen next. If the victim has been told that a lawyer will make contact, the later call from a supposed lawyer does not look like an anomaly: it fits the frame that has already been built. The announcement makes the exchange credible and reduces the number of questions the victim is likely to ask. An attacker who avoids questions avoids the moment in which the story might be checked.

Context also includes the past. A relationship built over a long time, a previous favour, an earlier instruction that was followed without problems: all of these become part of the frame. An attacker

who has spent time building trust does not need to explain every request, because the frame already makes it plausible.

9.4.5 Solidity instead of truth

A question that arises naturally is what the *true* meaning of an event is. In the social sciences this question is difficult to answer, and it is not necessary for the analysis. A more practical goal is to reach an interpretation that is solid, valid and reliable: solid enough to survive a stress test, valid in the sense that it accounts for the relevant evidence, and reliable in the sense that another analyst would reach the same conclusion from the same material. Context provides the metadata that guides this search. It does not give the final answer, but it tells us which elements must be considered before giving one.

9.5 Communicating is acting

9.5.1 Words that produce facts

Saying and writing are forms of doing. A sentence such as *"a lawyer will call"* is not only information: it creates an expectation and makes something happen. The same holds in institutional life. A judge who reads a sentence changes the legal situation of a person; a degree certificate is a document made of communication, and yet it has concrete effects on a career. Communication has consequences because people have learned to treat certain communications as binding.

These consequences depend on social norms. A teacher's request to stop an activity is effective not because of the teacher's personal power, but because of norms that apply to students and teachers alike. Norms are the shared rules that tell people what they should do in particular circumstances. They are part of the frame: they let us recognise which communications require a response, and which can be ignored.

9.5.2 The temperature of a message

Beyond its content, every message has a dimension that is harder to measure: its *temperature*. The temperature includes the degree of confidentiality, closeness and emotional tone that comes with the words. The phrase *"keep it under your hat"* carries a meaning that the words alone do not express. The same expression can be a joke among friends and an insult in a formal meeting, or even something more serious, depending on the frame.

In social engineering, the temperature of a message is often used to reduce questions. A request marked as confidential asks the recipient not to share it, and this request is itself a reason not to consult colleagues, who might otherwise have asked the questions that would expose the attack. The confidentiality of the request is therefore part of its function, and it deserves attention in the analysis.

9.6 The formal record: $R = (q, C, a)$

9.6.1 From narrative to record

An incident is a sequence of many communications and decisions. To analyse it, the chapter adopts a method inspired by the investigations of transport accidents carried out by the National Transportation Safety Board in the United States. The first step of that method is to formalise the process into simple, discrete elements, so that each element can be examined, questioned and, if necessary,

rejected. Here the elements are *records*, one for each request and the decision it produced:

$$R = (q,\ C,\ a)$$

q **(request or query).** What is being asked. Confirming a contact, preparing an operation, supplying information and executing a transfer are different requests, and they must not be treated as interchangeable. The action explained later must match the request.

C **(context).** The elements that were available to the recipient at the moment of the decision, seen from the recipient's perspective. C is the recipient's definition of the situation, not the analyst's. The analyst must be able to justify why each element is included in the context.

a **(action).** The action that must be explained. A reply, a disclosure, the approval of an instruction and the execution of a payment are different actions. Each needs its own record.

The brackets only keep the entries distinct. The record is not a calculation: it does not assign weights to secrecy, seniority or the sound of a voice. Its purpose is to make each claim easier to inspect and each gap in the information easier to locate.

9.6.2 Using the record well

Some rules make the record useful. The first is to decide whose action is being examined and at which moment. If the analysis moves from the decision of one recipient to the decision of another person, a second record is needed; mixing them produces confusion. The second rule is not to merge the micro-events of different decision-makers into a single record, because this removes the analytical advantage of the method.

The third rule is the most important. Information obtained later must not be placed in the context of an earlier decision. If an investigation discovers that a mailbox had been compromised, this fact belongs to the reconstruction of the incident, but it was not available to the recipient before the decision. Putting it in the recipient's context would attribute to the recipient a knowledge that the recipient did not have. The analyst's knowledge at a later time must not be transferred to the actors at an earlier time.

Finally, each entry should be accompanied by a short note stating where it comes from: whether it is a fact taken from a source, an interpretation, or a conjecture that still needs evidence. At the beginning of an analysis most entries will carry question marks. That is normal. The record makes these gaps visible, and the list of gaps becomes the agenda of the investigation.

It is tempting to try to list in advance every concrete item that could be observed in a social engineering incident. The attempt is unfruitful: the list would be as long as the distance between the Earth and the Moon and back, and it would change as technologies change. A better approach is to reason about the elements through the concepts of this chapter, and to review the analysis periodically, month after month.

9.7 Reconstructing an incident

9.7.1 Three stages of the method

The method used in this chapter follows three stages, adapted from the headings that the NTSB uses in transport accident investigations. The first stage is fact-gathering: the reconstruction of the available account, as complete and reliable as possible. The second stage is the analysis of findings: the development and testing of an explanation that connects the facts through the concepts introduced in this chapter. The third stage concerns recommendations, which are not addressed before an explanation exists.

In practice the work proceeds in levels. A first level gives the basis of an explanation from the reading of the case; each following level adds concepts, evidence and a more detailed analysis, until the concepts of the module are used together on the same case. The case itself does not change between levels: what changes is the depth of the reading.

The stages are not strictly sequential. An analyst begins with a first impression of the incident, gathers information, places it on a board and tries to connect the pieces. The connections usually raise new questions, and those questions send the analyst back to the facts. Each round changes the analyst's gaze on the same material: the scene does not change, but with more knowledge it is seen with different eyes, and the explanation becomes more precise or is replaced.

It is useful to keep a starting explanation: a short account, written from the first reading, of why an action may have taken place. This account is not discarded when the analysis develops. It is kept as the first version of the reconstruction and revised in the light of the analysis, so that the change in understanding can be seen.

9.7.2 Reported events and explanations

A reported event is not an explanation. Suppose a source says that a lawyer was announced, and that a caller later used the identity of that lawyer. The sequence can be reconstructed. If we then add that the announcement helped the recipient accept the call, we have proposed a connection that needs support. This is a legitimate move, because explaining means proposing connections, but it must be recognised as an interpretation. The ability to distinguish facts from interpretations is the first skill that the analysis of social engineering requires.

9.7.3 Sources and their position

Sources give different kinds of access. A news report may quote an investigator. A government account may report a technical agency's finding. A company may describe its own response in a public statement. Each source is situated: it occupies a precise place in a network of needs, knowledge, capabilities, willingness to say or to avoid saying, and interests. A company involved in an incident is willing to help the authorities and to compensate its customers, and it is also concerned with its reputation. This does not mean that the company is lying, but it means that its account must be read with its position in mind. The analyst should keep the attribution of each statement, especially when the statement concerns something that the analyst has not examined directly.

Information that reaches the analyst through a second-hand channel needs specific questions. What was the exact wording of the request? Is there a record of the check that was performed? Who approved the action, and what did that person know? Such questions turn a vague doubt into a request for evidence that can be obtained or that is known to be missing.

9.7.4 Explanations are provisional

Investigations of real incidents take months, sometimes years, because things take time to be understood and connections must be solid before a conclusion can be justified. The same holds for the analysis of a social engineering case. An explanation is a hypothesis that becomes stronger as it survives the evidence. It is not improved by forcing every uncertainty into a confident conclusion simply to reach an end. A good analysis makes its limits visible, and says which evidence would be needed to go further.

9.7.5 A story that does not need to justify itself

A story that does not need to justify itself is a fairy tale. An evidence-based reconstruction is different: it separates facts and evidence clearly from interpretations and conjectures, so that each

claim can be checked against its source. The distinction is simple to state and difficult to keep, because interpretations tend to enter a narrative without being marked as such.

9.7.6 Question marks are part of the model

At the beginning of an analysis most questions remain open, and some will probably remain open at the end. The question marks are therefore not a failure to be removed as quickly as possible; they are part of the model, because they show what the analysis does not yet know. The gap between the reconstruction that the account allows and the evidence the account actually provides is a guide to further work: which document to request, which person to interview, which record to check, and which hypothesis would change if the answer were different.

Notes

For example, the disappearance of flight MH370 remained only partly explained for years. The investigation produced partial answers and conjectures, and it paused when the effort no longer produced new evidence. It restarted when a new element appeared, such as debris reaching a shore. The same pattern applies to old crimes that are reopened when new techniques, such as DNA analysis, become available.

9.7.7 Investigations end, and restart

An investigation has no fixed end. It may stall, when effort, money or new tools no longer produce evidence, and it may restart when a new element appears, or when social or political pressure asks the authorities not to give up. A satisfactory solution and a stall are two possible end points, and in both cases the analysis can start again. For this reason a conclusion should always state what would reopen it.

9.7.8 Recommendations come last

Public narratives of incidents often reverse this order. Media need a clear story quickly, and they ask for explanations and recommendations before the facts are established. The method proposed here asks for the opposite: first the reconstruction, then the explanation, and only then any recommendation, which must be linked to what the analysis has actually established. Partial recommendations and partial explanations are legitimate outcomes, because a new incident may always happen before the analysis is complete.

9.8 Status, role and authority

9.8.1 Status and role

Two concepts describe the position of a person in a social structure.

- **Status** is the rank of a person in a social hierarchy.
- **Role** is the behaviour expected of a person who holds a certain status.

A position is a point in a network of responsibilities and expectations. The behaviour expected of its holder is a different matter, and neither tells us what the person actually did. People can hold a position and fail to meet the expectations attached to it. People can also disagree about what a position requires in a particular situation. This is one reason why many positions are codified in rules and job descriptions: to reduce the gaps in understanding between the people involved.

In a case of social engineering, the relevant position is usually the one the sender claims, and the question is what that position makes relevant for the recipient. A group chief executive is not important in an abstract sense; the position matters because it is invoked in relation to a subsidiary and to a specific operation. The concept of role helps to specify the relationship that must be investigated. It does not explain by itself why the recipient complied.

9.8.2 Authority

Authority is the tendency to defer to people whom we take to be knowledgeable or entitled to direct us. Authority is linked to status and roles: the higher the role, the stronger the tendency to defer to it. It is tempting to use the word "authority" as a complete explanation, but the word covers different relationships that must be kept apart:

- a person may be senior without having expertise in the matter;
- a person may have expertise without being authorised to give a particular instruction;
- a person may be entitled to communicate an instruction on behalf of someone else.

When an explanation uses the word authority, the analyst should ask which of these relationships is meant.

A useful way to think about authority is as potential energy. The status attached to a role is the height from which the potential starts, and it is higher for a senior role than for a junior one. When a person communicates an order or a request, the potential becomes kinetic. For this reason an attacker has an interest in presenting itself in the highest role that is plausible for the request, because the higher the role, the more energy is available to make the request effective.

9.8.3 Claimed, actual and attributed positions

Three positions must be kept separate when an incident is analysed.

Claimed position: the position the sender presents, for example "group chief executive".

Actual position: the position the reconstruction establishes for the sender. In a fraud, the actual position is often different from the claimed one, and this is known only after the incident.

Attributed position: the position the recipient took the sender to hold at the time of the decision. This must be investigated, not assumed.

It is tempting to jump from the claim to the attribution: the message said "chief executive", the operation went ahead, so the recipient must have believed the claim. This may be a reasonable hypothesis, but the action alone does not tell us how the recipient understood the message. The recipient may have recognised the position, may have checked with someone else, or may have had another reason to proceed.

An authentic identity does not settle the question either. A genuine equipment coordinator may send a request that does not belong to their responsibilities. The analysis must therefore keep three questions apart: what did the sender claim, what does the reconstruction establish, and what did the recipient understand. Each of these questions needs different evidence.

9.9 Expectations and social norms

9.9.1 Empirical and normative expectations

An *expectation* is a belief about what other people will do or think. Two kinds must be distinguished.

Empirical expectation. A belief about what relevant others actually do. If messages in a group are usually answered on the same day, a member may expect a reply on the same day.

Normative expectation. A belief about what relevant others think ought to be done. It is a belief about beliefs, not simply one's own opinion about the right action. The member may believe that the others consider a same-day reply part of being a reliable participant.

These beliefs can come apart. People may often reply late while still saying that everyone should reply promptly. And a person may judge a next-morning reply to be perfectly reasonable, while believing that the other members would regard it as too late. The normative expectation concerns the second belief: what the person thinks the standard is.

An expectation is not a command that automatically produces behaviour. A person can understand what others expect and act otherwise, and can also be unsure which expectation applies. The concept therefore asks a question about the relationship, and does not give the answer. In the analysis, each expectation should be specified: who holds it, which relevant others it refers to, which situation is treated as comparable, which behaviour is expected, and what evidence shows that the expectation entered the decision. A phrase such as "the person expected disapproval" is too generic until we know from whom the disapproval would come.

Predicting an event is not, by itself, an expectation about compliance. Predicting that a lawyer will call is first of all a linguistic act, and the expectation must be connected to the object it concerns.

9.9.2 Social norms

A *social norm* is a prescription: it says which conduct is appropriate, or forbidden, in particular circumstances. Norms are the rules through which a society guides the behaviour of its members and makes it more predictable. Predictability is not certainty. Someone may decide not to follow a norm, and in doing so may betray the expectations of others. But the function of the norm is to reduce the uncertainty of behaviour.

Three properties of norms are important for the analysis.

- Norms are **cultural**: they are built by people interacting with one another. They are not a fixed feature of the world, and they do not come from outside human society.
- Norms are **situated**: they belong to a particular place and period, and they change across countries, groups and time.
- Norms both **prescribe** and **proscribe**: they tell people what they should do, and what they should not do.

9.9.3 Separating norms from observed behaviour

A norm is not proved by observing a behaviour, and the absence of a behaviour does not prove that no norm applies. Suppose a group agrees to share a draft early enough for review, and drafts regularly arrive at the last moment. This shows that the deadline was not respected. It does not show that the expectation of review time has disappeared. If members complain or apologise, the norm is still active even though it is breached. If everyone treats the deadline as flexible, then there may be no shared norm at all. The behaviour and the prescription therefore need separate evidence.

Without this separation, an analysis falls into a circle: one observes a result, imagines a norm that would produce it, and then uses that norm to explain the result. A written rule is evidence of a stated requirement, but explaining an action also requires knowing whether the person had access to the rule, understood that it applied, and could recall it at the relevant moment. The absence of a rulebook does not prove that no relevant expectations existed.

The word *culture* requires particular care. It is easy to write that "the culture made them act this way". Such a sentence is useful only if it says by whom which conduct was expected, and what evidence shows that the expectation mattered in the case. Otherwise the word becomes a shortcut that hides the relationships we are trying to understand.

9.10 The definition of the situation

To recognise which expectations apply, people need to understand what is happening. Sociologists call this the *definition of the situation*. Most of the time it happens automatically. A request for a document is immediately understood as part of project coordination. A meeting announced by a colleague is understood as routine feedback. These definitions feel natural because we have used them many times, and they make everyday life possible.

Goffman studied how the conduct of the participants influences the understanding of what is taking place. The same situation can be defined in different ways, and the definition changes which conduct becomes relevant. Consider a university meeting described as routine feedback on a project. You prepare an account of your progress in an informal way. Then you learn, from an official source, that the meeting is in fact a formal assessment, and there is no time to change your preparation. The invitation may use the same words and the activity may be the same, but the situation is now defined differently, and different questions become relevant: what will happen, is this way of presenting appropriate, what will I be asked?

The definition of the situation is essential in the analysis of social engineering. An attacker presents an activity to the victim, for example a confidential business operation. The documents, the calls and the messages can then be read as contributions to that activity. The analyst, however, knows the actual situation, which is a fraud. The two definitions must be kept separate. The analyst must avoid writing the analyst's own interpretation into the head of the recipient. The question is not only whether the person should have known the truth, but whether the truth was knowable at the time, given the situation as it was defined for the person.

The definition of the situation also helps to connect contacts across time. A first message announces a person who deals with the legal side of a transaction. A later call presents someone as that person. Documents then appear within the same proposed operation. Each element contributes to defining the situation, and together they make the situation credible for the victim.

9.11 Case A: the confidential acquisition

Case history: Case A (banking group subsidiary)

A message arrives on the phone of the chief executive of a banking group's subsidiary, from a number that they do not know. The sender says that they are the chief executive of the group. The message asks the subsidiary to carry out a confidential acquisition abroad. The parent company, the message explains, cannot handle the operation directly, because a leak could jeopardise the deal. The message announces that a lawyer will make contact. The lawyer then calls, presenting themselves as a lawyer from a recognised firm, and the voice on the call is reported to have been imitated with artificial intelligence. The subsidiary's chief executive receives a confidentiality agreement, an apparent power of attorney and payment instructions with bank details. A separate caller, presenting as the chief executive of the subsidiary, reaches the person responsible for treasury and payments, and asks for urgent confidential transfers. Money is transferred to accounts abroad. The fraud is detected soon after, and some of the funds are blocked or recovered, but a significant part is still missing.

The analysis of Case A starts with the positions. The sender claims to be the group chief executive, and the recipient is the chief executive of a subsidiary. Both positions matter, and both must appear in the record. The new number is an obvious warning only with hindsight: at the moment the message arrives, what the analyst knows is the relationship that the sender claims and the task the message presents as part of that relationship. The message presents a communication from the top of the group to someone with a position inside it, and it asks for an operation that the subsidiary is supposed to carry out.

The confidentiality of the operation has a specific function. It explains why the parent company cannot act directly, and why the request must not be discussed with colleagues. The announcement of a lawyer then prepares a place for the later call. When the call arrives, it does not look like an anomaly, because the frame has already anticipated it. The sequence of the messages therefore gives a concrete hypothesis: the earlier announcement may have made the call read as part of the same operation.

The documents perform three different functions. The confidentiality agreement concerns secrecy. The apparent power of attorney provides a basis for acting on someone else's behalf. The payment instructions are a command, because they specify where the money must go. Together they give the operation a concrete form. The presence of a document, however, does not establish that it is valid, and a payment instruction is not the same as a completed transfer. These distinctions must be kept when the sequence is reconstructed.

Finally, the subsidiary's chief executive and the person in treasury received different contacts, and they did not necessarily know the same things about the operation. The analysis should therefore not treat the contacts as independent confirmations of one another, just because there were several of them. Attacks conducted through communication usually use many messages over time to make the story appear more realistic, and several contacts can all belong to the same deception.

9.11.1 Exercise on Case A

A useful exercise is to choose the single sentence of the case that would best explain the incident with the sociological concepts, rather than with technical details. A good choice usually concerns the context and the roles, and not the technology. This is the first step of the analysis, because it identifies the relationship that must be explained.

9.11.2 Variations on Case A

A powerful way to test an explanation is to change one element of the case and observe whether the explanation changes with it. If the request came from a junior employee instead of the group chief executive, what would have to change in the explanation? The interesting point is not to predict whether the recipient would refuse, but to identify the relationship on which the explanation depends. The same test applies to a request coming from a union representative, urging the subsidiary to act quickly. In both variations, the response depends on the perceived role of the sender and on the legitimacy of the request. A junior employee does not make every message illegitimate, and a senior person does not make every request legitimate. Making the dependence explicit is the purpose of the variation.

9.12 Case B: the institutional mailbox

Case history: Case B (institutional mailbox)

A government's national cyber security agency analysed a sample email supplied by a company, and established that an institutional mailbox had been compromised. An unauthorised party used this genuine institutional channel to send fraudulent requests for customer information. The company complied. It stated that its own systems and customer funds were not affected, but the incident involved the disclosure of customer information. The company then offered assistance to the affected customers, including cover for the cost of replacing identity documents where needed. A data-protection authority asked banks to check for similar communications, as a precautionary measure.

Case B is useful because the channel is different. In Case A, the sender used a message and a phone call. In Case B, the channel is an institutional email that is genuine. This makes it necessary to examine two things separately: the authenticity of the channel and the legitimacy of the request. The channel was not fake, so there is no forged evidence to rely on. The question moves from "is this email real?" to "could a request of this kind come from this office, and was the request checked in the appropriate way?"

Two points about time are important. The compromise of the mailbox is a finding reported after the incident. It helps us reconstruct what happened, but it does not show what the recipient knew before disclosing the information. The analysis must keep apart the information available after the discovery of the incident and the position of the actors while the incident was unfolding.

The company's statement that its systems and funds were unaffected is accurate as far as it goes, but it concerns systems and money. The disclosure of customer information is a different kind of consequence, and it must remain in the account. The verification of the request is a separate question from the technical state of the mailbox. An institution entitled to ask for data creates a duty to comply, and speed is part of that duty. But a request still needs a second check: is the sender entitled to make this specific request, and does it come from the office that normally handles such requests? Hindsight makes these questions easy; the analysis must ask whether they were answerable at the time.

9.13 Three constants of social engineering

Lists of attacks change quickly, while principles change more slowly. For this reason the chapter relies on three principles that Hatfield (2018) identifies as constant across the social engineering attacks known to him. They are sociological and philosophical rather than technical, and they can be applied to an incident whatever its channel.

9.13.1 Epistemic asymmetry

The word *episteme* comes from ancient Greek and means knowledge. Epistemic asymmetry occurs when one person or group enjoys a significant advantage of knowledge over another within a specific domain to which that knowledge applies (Hatfield, 2018). Asymmetry is always relative to a domain: an attacker may know how a pretext is built, while the recipient may know the organisation far better.

Notes

For example, a teacher knows more about sociology than the students on average, but not in general, and no single teacher holds all knowledge.

In social engineering the attacker holds a significant advantage over the victim with respect to the knowledge the victim needs to judge the request. Two examples show how this can operate.

Notes

For example, a senior executive of a traditional company may find it hard to imagine that a message in the name of the chief executive comes from a generative AI system rather than from the human they have in mind, because their sense of authority rests on seniority rather than on technical updating.

Notes

For example, a certified email address certifies the source of a message, but not its truth or the legitimacy of each request.

These are two different things, and an analysis must not confuse them.

9.13.2 Technocratic dominance

Foucault's remark that knowledge is power is a useful starting point, provided that power is distinguished as potential or actual. Potential power is power one could use but decides not to use. Epistemic asymmetry describes a situation, and it can exist without anyone exploiting it. Technocratic dominance occurs when the holder of technical knowledge uses it to change the behaviour of others, reducing their power or authority within the affected domain (Hatfield, 2018).

Notes

For example, a physician knows far more medicine than the patient, which is an asymmetry but not a dominance. If the physician recommends a surgery and the patient decides, even after persuasion, the relation is legitimate. If the patient is taken into surgery against their own choice, the physician has moved into dominance.

Asymmetry is therefore a precondition of dominance, but not every asymmetry is dominance. In social engineering the attacker looks for an asymmetry wide enough to make the attack succeed, and then works to make it concrete, so that the victim's behaviour changes. The analysis of each incident asks which behaviour changed, and whose power or authority decreased, within which domain.

In Case A, the subsidiary's chief executive never called the real chief executive back on a known number and never involved the IT function, because the request asked for speed and secrecy.

9.13.3 Teleological replacement

Teleological replacement occurs when a person or group manages to substitute, in another individual or group, the original purpose of their behaviour with that of the social engineer, often by altering the target's behaviour itself (Hatfield, 2018). The word *telos* means distant, goal or purpose, and "television" comes from *telos* and *vision*: seeing from a distance. Teleological replacement works as a kind of remote control: it directs attention, time and effort towards what someone else considers urgent and relevant.

Marketing offers familiar examples.

Notes

For example, messages such as "only until Sunday" or "last pieces" push purchases that were not planned.

Discounts are not necessarily fake; creating special moments can be part of a business model. The test is simple: would the person have bought earlier, or at all, without the urgent message? Large companies usually do not scam their customers, but they use urgency, scarcity, unity, liking and profiling to make the customer adopt the company's goal. The reply "I wish I could, but it is too expensive" describes a goal that has already been replaced. Trends show the same mechanism at a cultural level: when a behaviour becomes the norm, it pressures individuals to adopt a goal that is not their own.

For the analysis, three elements must be kept apart: the stated purpose, the actor's intention, and the outcome. In Case A the subsidiary's chief executive acted genuinely, believing the operation was an acquisition. The teleological replacement was so effective that the attacker's goal became the victim's own, and the result was a diversion. The replacement may be unconscious: the victim may recognise the risk only later, when it is too late.

9.14 Recordings and the epistemic backstop

The word *epistemic* comes from the Greek *episteme*, knowledge, and refers to the way we produce, share and deem knowledge reliable.

Disputes about what was said or done were historically settled first by power, then by debate. The word "technocracy" itself comes from *kratos*, power: in ancient times kings and tyrants declared what was just and true. In the modern judicial system a prosecutor and a defence argue before a judge or a jury, who weigh the evidence. This structure was designed to limit the abuse of power, even though it can make mistakes. In late modernity recordings, videos, sounds and voices became concrete proof, and seeing or hearing came to be treated as believing.

Rini (2020) calls such recordings an *epistemic backstop*: video and audio recordings regulate our testimonial practices, sometimes bluntly and often subtly. The backstop works even before a dispute, because the possibility of a recording constrains what people are willing to say. A question structures the rest of the analysis: when someone says "that is not what I said" and another replies "there is a recording", what work do we expect the recording to do? The question returns in the section on contested evidence.

9.14.1 From speech to recording

The history of evidence explains why recordings carry so much weight. The Latin saying *verba volant, scripta manent* expresses the difference: speech flies away, while writing survives the writer and can be moved, shown and checked. A written text can still be denied, but if someone shows that the handwriting is the author's, or that a reliable person took notes of the words, the evidence becomes

stronger. Modernity moved from writing to printing, from printing to industrial printing, and then to the recording of voices and images. Over roughly the last two hundred years, video and audio have worked as a backstop: a pillar in the process of establishing what was true and what could be proved.

9.14.2 Knowledge we do not check ourselves

Most of what a person knows is never checked personally. We trust institutions, such as constitutions, the selection processes of teachers and police, and a long chain of knowledge accumulated over generations, and few of us can inspect the evidence behind that chain. The same holds for science. Physics today is neither Newton's nor Aristotle's: many thinkers, in theory and in experiment, took part in building it. Aristotle is still regarded as one of the most relevant philosophers of Western culture, although his ideas are thousands of years old. Many of the ideas we rely on are taken for granted, although we could explain only a few of them in detail. This is the normal condition of knowledge in a complex society, and it is why evidence that others can check has so much value.

9.14.3 The backstop as deterrent

Multimedia data work as epistemic backstops in several ways. The first is deterrence: recordings work even before any dispute starts. Cameras, phones, GPS devices, and tickets that log a journey on a train or a bus are everywhere. If people know that what they say or do is recorded, they assume it will be visible and may be taken as the truth, and this changes their behaviour.

Notes

For example, a taxi driver may install a camera from the first day of work, because accidents and harassment have happened in that job. The camera protects the driver if something goes wrong, and it discourages people who intend to behave badly.

The effect works like an insurance. It protects in case something happens, and it influences others, who are less inclined to act when the protection is in place.

9.14.4 The regulatory function

A second function concerns oral disputes. Without a recording, a dispute can last for days or months: "No, I never said that", "Yes, you did", "You misunderstood me". When one party knows that a recording exists, the dispute often ends, even though nobody watches or listens to it. Many people accept the existence of the recording as proof without checking any element of it. In sociological terms this is a *regulatory function*: the existence of something affects the behaviour of the actors, even when it is never consulted.

The function also shapes how events are understood afterwards.

Notes

For example, after the crash of a business jet in Florida, conspiracy theories appeared quickly. A conspiracy mindset does not accept evidence, so no backstop can persuade it. Still, the most widely accepted account became possible because cameras had recorded the crash. Reconstructions by people who are not used to analysing such incidents can be shaped by stereotypes: the speed of the aircraft led some to imagine a missile. The existence of several records did not stop speculation completely, but it reduced its reliability and its spread.

This is the regulatory function at work: when something solid exists, it provides a reliable explanation, and it reduces disputes by relegating unsupported claims to weak versions.

9.14.5 A recording as corrector

A reconstruction may be disputed at first and then corrected by a recording, so that the account becomes reasonably difficult to dispute. It is much more probable to make a mistake by accepting the initial version than by deleting or modifying the recording to fit it.

9.15 Contested evidence

9.15.1 Seeing is believing?

The idea that seeing is believing is no longer generally valid, and it is becoming less valid, because generative artificial intelligence produces increasingly realistic content. The source behind this point dates from about 2018, roughly a year after the transformer paper *Attention Is All You Need* (2017), which is usually taken as the starting point of today's generative AI. Two consequences follow. An AI-enabled forgery can challenge the trust placed in video and audio. And a convincing forgery can make a genuine recording easier to deny.

For some scholars, technology has two faces: it helps with many tasks and speeds up processes, but it also wears down the tools that made truth reachable at a distance.

9.15.2 When even genuine evidence loses weight

The question becomes how societies can deal with complexity and controversy when recording reality is no longer a strong proof for resolving a disagreement. The value of digital recordings is reduced for opinions and for possibilities, though not for epistemic backstops in general. A recording of a crime may soon be treated in court at the same level as testimony. Testimony is not reliable on its own; it involves many parts and needs checking. Recordings, time stamps and digital signatures were meant to resist this, but almost anything can now be fabricated, which makes it harder to tell true content from fabricated or modified content.

Two risks follow for anyone investigating incidents in cyberspace. The first is that fabricated content is taken as genuine. The second is that people become so sceptical of technology that even genuine content meets suspicion. This scepticism can spread like a pandemic, and a society that cannot separate the benefits of technology from its risks becomes unable to protect itself.

The new situation forces people to make choices they did not have to make before: which calls and messages from trusted people to believe, and which to block or delete.

Notes

For example, email and messaging phishing is increasing, so a call or message from a trusted person may now be treated with suspicion, and blocked or deleted. Children are taught not to accept anything from people they do not know. This is sensible, but it is also a sign of a society that is becoming sceptical. The image of a door helps: a person who cannot tell a good visitor from a dangerous one may keep the door closed, or open it carelessly.

The wider risk concerns the shared basis of a society. If people lose the agreement on which principles and methods are acceptable for establishing, even partially and conditionally, the truth of a dispute, then a society cannot build a common explanation of what happened. Societies are always interested in controversies, and when these become too strong they can break a society: wars, economic crises, injustice, shortages of food and water, and revolutions. Historical examples include

the French and Russian revolutions and the period after the first industrial revolution, when the division between "us" and "them" became central.

9.15.3 A shared alphabet of method

A recurring question is how a society can hold together if it cannot agree on the principles and methods used to decide the truth of a dispute, when the truth itself may change over time. An engineering analogy helps. A rocket cannot reach Mars if its engineers do not agree on mathematics and physics. Contesting the validity of another method is different from disagreeing about a result: the first breaks the common alphabet in which results are discussed at all, while the second can be resolved inside it.

Notes

For example, teachers of different courses might disagree about the state of the art, and some might invent new mathematics without empirical evidence, at least as a joke. The problem is not the shape of the spacecraft, its fuel or the skill of the crew: it is the shared alphabet.

9.16 Case A revisited: sources, requests and records

Case A can now be read with the tools developed in this chapter. Each step separates a different question, and the steps are not interchangeable.

9.16.1 The voice as a source

Recordings and digital content cannot by themselves prove the reliability of their contents. A person who does not know this becomes a victim of social engineering. In Case A, a message is followed by a call, and the voice of the person imitated is reported to be indistinguishable from the real one, in tone, register, vocabulary and inflection.

The word *aesthetics* is used here in a technical sense: not beauty, but the formal characteristics of a message. The aesthetics of a messaging app are its interface and its emoticons; for a voice, they are its sound and waveform. Generative artificial intelligence is reaching the level of statistical likeness to human communication that makes these characteristics convincing. When an attacker reaches that level of likeness to a genuine source, the medium stops working as an epistemic backstop, and the recipient is exposed.

9.16.2 A recording produced later

Suppose the situation of Case A continues. This is a scenario invented for teaching, not a report of what happened. After the incident, someone produces a recording as proof that the lawyer gave the instructions. The first question is where the recording comes from. Even before generative AI, multimedia content could be altered, and forensic work has long analysed digital traces to establish whether a piece of evidence is authentic.

9.16.3 Evidence and proposition

A recording must support two different claims: who spoke, and what request they made. These are entangled, but they must be separated. The *evidence* is the content, the message or the digital file; the *proposition* is the request. A piece of evidence e may represent a proposition p without p being true, and contesting e as fabricated does not by itself establish that p is false. Having the evidence

does not imply that the source is genuine, and having the proposition does not imply that the request is appropriate.

In Case A, the inquiry into the source and the inquiry into the request must be kept apart. A legitimate request can come through an inappropriate channel, and a fake source can produce a true request.

9.16.4 Attribution and mandate

The starting hypothesis is that the lawyer made the request, and the next question is whether the request falls within the lawyer's mandate. One should not take for granted that, because a source is genuine, its content is also appropriate. In the reports on transport accidents studied through the NTSB method, the actors involved are, in the vast majority of cases, genuine. The problematic cases arise when someone makes requests that go beyond the mandate attached to their role.

This step is boring, but it is necessary. If one does not examine every detail, a variable becomes a constant and is no longer disputed: an association that seemed a necessary premise becomes an unexamined assumption.

9.16.5 Keeping the actor and the moment

An analysis involves several variables, and each step of the reconstruction needs its own record. Every record addresses a request, a context and an action, and every record is situated in a network of people, roles, expectations, requests and actions. Each record R_i concerns a particular recipient at a particular moment.

Notes

For example, take the request to make a money transfer. The first person who receives it is the subsidiary's chief executive. Reconstructing the chain from that person's perspective gives a record R_1: q_1 is "make this money transfer as soon as possible"; C_1 is "this is a secret acquisition, keep it under your hat, otherwise we lose the opportunity"; and a_1 is the subsidiary's chief executive transferring the money as instructed.

When reconstructing C_1, the person to consider is the recipient, and the context must contain what would probably have been available to that person at the time, not the analyst's knowledge afterwards. Where the analyst is uncertain, a question mark is placed in the record.

9.16.6 Two recipients, different records

Following the chain further, a second record is needed for the person responsible for treasury and payments, who probably executed the transfer. The two records share some elements, because both people work in the same organisation, but these elements cannot simply be copied from one record to the other. The treasury officer may have different evidence to consider: for example, how long the person has been in the company, and whether the company has often changed its CFO or its chief executive, which could suggest defensive decisions aimed at doing or undoing something.

9.16.7 The executed transfer

Each action comes with its own variables. For a money transfer, the action under examination is identified by the selected recipient and the moment, because more than one transfer may have been made. The executed transfer is a function of the amount and the destination: $T(m, d)$, where m is the amount and d the actual destination. An instruction to transfer and an executed transfer are different

things, because an instruction is not the same as a completed transfer. The action $a_i = T(m_i, d_i)$ must therefore be reconstructed from the proof of the transfer, not from the instruction.

9.16.8 Two hypotheses about the destination

The analysis of the transfer rests on two hypotheses.

H1. The executed transfer used the destination given in the instructions. To test it, one asks for the proof of the bank transfer and compares it with what the instructions said.

H2. The instructed destination belongs to the set of destinations controlled by the attack network. To test it, one relates the destination put in the message to the destinations that the attacker controls.

H1 matters because, in a social engineering attack, a last-minute change or a mistake may occur, so one must know whether the instructions were executed, and how. When many transactions are involved, each instruction must be followed to its own transaction. This is one reason why the investigation of complex situations can last months or years. H2 concerns the scheme itself: one must establish a link between the destination in the message and the bank account of the attacker.

9.16.9 From two premises to a conditional conclusion

If both hypotheses are supported by solid evidence, the executed transfer went to a destination that belongs to the attacker's domain, and one may conclude that the case is a social engineering attack. The result is conditional: it holds only if both premises hold, and it should not be treated as a single block. Each premise has its own evidence and its own gaps.

The same method applies to Case B, where the analysis connects the institutional address with the disclosure of customer information. Each link in that connection needs its own evidence. Different people can work on different hypotheses independently; the results are then compared and integrated into a first reconstruction of what happened. The groups then return to the document they had worked on and develop their reasoning.

9.16.10 Purpose is not a hidden equality

Even if both hypotheses are proven, this says nothing about what the recipient really intended. The recipient may have been naive, or may have been a partner in the crime, but these are different questions, and the recipient's intention must be treated separately from the reconstruction of the transfer. The stated purpose (a confidential acquisition), the possible effect (resources reaching a destination controlled by the attack network) and the elements still to be established (individual intentions, the loss and the legal classification of the conduct) must be kept apart rather than merged. In particular, the amount of the loss, the gap between the perceived and the actual destination, and the possible offence are separate elements.

9.17 Communicating an analysis in progress

An analysis can be communicated while it is still in progress, and the way this is done matters. Clear language without complex jargon helps, and uncertainty is kept as the protagonist rather than hidden.

Notes

For example, the spokesperson of an investigation into an aviation accident, speaking at a press conference, used plain language and said “we don’t know yet”. The spokesperson refused to speculate and did not give weight to conspiracy questions from journalists. Expressions of empathy and condolence are also needed when people have died.

The investigators kept their focus. They distinguished what was already known from what had to be investigated, and described what was complicated without personal judgement. The same discipline applies to a social engineering analysis. We cannot assume that the recipient had the same goals, perspective or interests as the attacker.

Notes

For example, in an aviation accident one should not conclude from the age of a crew member that they were negligent: age does not prove anything. A person, especially one who cannot defend themselves, should not be judged for seeming too young for a role, unless a negligent action has been proven.

Refusals to answer need the same care. If someone refuses to answer, they should not be treated as a partner in the incident or as a suspect without proof. If the mandate allows the question to be asked, the law may provide a way to obtain a reply; if not, one cannot draw inferences from silence. Nor should one attach prejudices about whether someone answers, is literate or seems nervous, because one does not know how they react in the situation.

9.18 Influence: why some requests are accepted

Social engineering works because people follow patterns of influence that are shared by almost all human beings. The psychologist Robert Cialdini described seven principles of influence, studied in psychology, social psychology, consumer behaviour, diplomacy and marketing. These contexts share many elements with social interaction in general, so their findings can be adapted to the analysis of social engineering. This section introduces the seven principles: reciprocity, commitment and consistency, social proof, authority, liking, unity and scarcity. The principles are not a checklist of attacks. They are patterns that help to explain why a request was accepted.

9.18.1 Reciprocity

Reciprocity is the rule that obliges us to repay what another person has given us. It is one of the most widespread social norms. It requires no written contract, and it appears in every culture, in different forms. Its great power is that it binds people without force: they feel obliged, not threatened.

Consider a classmate who spends an evening helping you to recover a broken project. The following week, the same classmate asks you to swap presentation slots. The earlier favour creates an expectation of repayment, even though nothing was agreed in writing. The request is not a threat, but it is made possible by the earlier exchange.

Reciprocity can also be turned into pressure. A past secret, a favour that was never returned, or a debt that was never discussed can be used to force cooperation: *“I kept that secret, and now I need your help.”* In such a case, the question for the analysis is what the earlier favour contributes to the new request. Receiving help does not give anyone permission to carry out a riskier action.

9.18.2 Commitment and consistency

People want to act in ways that are consistent with what they have already said or done. Once someone has accepted a commitment, and a role has been attached to it, new duties that are consistent with the first one feel obligatory. The commitment creates a frame in which the new request appears to follow naturally.

Consider a student who volunteers to organise the final submission of a group project. Later, the same student is asked to take on another coordination task on the same project, even though their own section is not finished. The first commitment makes the second request feel consistent with it, and refusing it feels like a break with what was already accepted.

This principle is important in long relationships of trust. An attacker who obtains small favours or small commitments over a long period can use the accumulated consistency to make a much larger request appear coherent with what has already happened. The earlier relationship is not a neutral background: it is part of the context that makes the later request plausible.

9.18.3 Social proof

People often decide what to do by observing the choices of others whose judgement they respect. Suppose you are choosing an optional workshop on a subject you do not know well, and several students whose judgement you trust have already enrolled. The inference is simple: they chose it, so they probably know more about it than I do. This is social proof. It is a shortcut that often works, because the choices of others carry real information, but it can also be exploited.

Whose choices count as evidence, and why? The question is useful in the analysis of an incident, because it asks which people the recipient was observing. A colleague who has already complied, a senior person who has already approved a similar request, or a group of peers who have followed an instruction: each of these can make the recipient more inclined to comply.

Social proof is not a guarantee. The inference can be biased, irrational or even dangerous: in a panic, people look at one another for guidance, and the collective result can be a tragedy. Even so, relying on others has a rationality of its own, because the choices of others have carried useful information for most people in most situations.

We do not treat every other person as a source of social proof. We select those who count for us: relatives, partners, friends, teachers, colleagues, the people with whom we share a community or a cause, opinion leaders, public figures and politicians. The relevance of a person is dynamic and depends on the context. It can also be a stranger met at a particular moment, whose name we never learn. In the analysis, the question is therefore not whether social proof existed in general, but which relationship between the actors may have played this role, and what evidence supports that relationship.

A classic study carried out in New York shows how strongly the presence of others changes behaviour. Researchers had one person, or a group of up to fifteen people, look up at a window on the sixth floor of a building, and filmed the passers-by. With one observer, about 4% of them stopped to look as well; with fifteen observers, the share rose to around 40%. The window and the street did not change, only the number of people who appeared to be paying attention. The lesson is not that every crowd is persuasive, but that the visible choice of many people can change what seems worth doing.

9.18.4 Authority

Authority is, as seen above, the tendency to defer to people whom we take to be knowledgeable or entitled to direct us. The principle of authority is linked to norms, expectations and roles: the higher the role, the stronger the principle. This explains why attackers often present themselves as the most senior person who could plausibly make the request.

Authority is also communicated through symbols. A classic demonstration in social psychology shows that the same request, made in the same environment, obtains different levels of compliance depending on the appearance of the person who makes it. What changes is not the content of the request, but the signals of the role. Dress, environment and the way a person presents themselves are ways of communicating authority, and they shape the first impression on which the rest of the interaction depends. Attackers exploit this: they dress, speak and present themselves in the way that a more authoritative role would, because they know that the principle of authority operates on these signals.

The practical lesson is that authority is not a property of the person alone. It is a property of the relationship between the person, the role they claim and the context in which the request is made. A good analysis therefore asks which role is being invoked, which signals support it, and whether the request belongs to that role.

9.18.5 Liking

Liking is the tendency to agree more readily with people we like, and the things that make us like someone are more mundane than most people expect. Liking is among the strongest forces that drive attitudes and behaviour. It brings both biological and psychological rewards: eating, enjoying a hobby, succeeding, spending time with friends, receiving the feedback we were looking for, and discovering that others enjoy what we enjoy.

Liking does not require complicated things.

Notes

For example, two people meet on a court in a park and discover a shared passion, and a teacher replies to an email within hours.

The most striking example is an experiment with young women who were approached by a stranger. Some of them had been led to believe that they shared the stranger's birthday. Asked to review an eight-page essay, more than six in ten of those who believed they shared the birthday agreed; the control group agreed much less often. The result is explained by the fact that a person we have never met becomes a satellite of our own characteristics: a birthday close to ours is enough to make us remember them. A small shared characteristic is enough to create a feeling of closeness.

In an attack, liking can be built in stages. A friendly contact in a student community starts a conversation around a hobby and later asks the recipient to confirm a student account through a link. A welcome conversation and a legitimate account request require different evidence. Liking explains why the first stage is accepted; it does not establish that the second stage is legitimate.

9.18.6 Unity

Unity is the tendency to be far more open to influence from those with whom we share an identity: family, hometown, tribe, cause. Unity and liking overlap but are not the same. One can like a person without feeling part of a group with them, and one can feel part of a group without liking each member. Organisations build on unity through team-building, welcome events, welfare and off-site weekends. A company that invests in them does not expect everyone to like each other; it expects a shared identity to reduce conflict and to lead members to pursue the team's goal, not only their own.

What matters here is as much the belief of those who decide as the actual effect of the activity: an activity is worth organising when those who decide perceive it to work, whether or not its effect can be measured.

Notes

For example, a sports team sends its players to a hotel before a decisive match. It follows the same logic, even though nobody knows how much it affects the result.

Notes

For example, a student robotics team asks for volunteers. The team leader rotates and you may not know them, yet you feel entitled to act for the team and to recruit new members. This principle is called unity.

A classic experiment placed people in three groups: one organised around Manchester United supporters, one organised around football in general, and one that did not discuss football. A researcher wearing a Manchester United shirt then simulated an injury. The Manchester United group helped most, even though they did not know the person. Surprisingly, the group of fans of different clubs also helped, even when the injured person wore a rival shirt. Unity works at different scales: at one end it coincides with liking, while at a wider scale one can feel close to the community of a sport while disliking some of its members. The same mechanism explains why rival fans act together when something very good or very bad happens, and why players who compete in club matches cooperate in national teams.

Notes

For example, during a derby in Torino a Juventus supporter was seriously injured, and supporters of the home team asked to stop the match. Whatever one thinks of the request, it is explained by a higher level of unity, which overrides rivalry.

Notes

For example, in Formula One two drivers who race against each other on track belong to the same team, and the identity of the team can outweigh their personal rivalry.

Unity has two faces. It gathers similar people into a group, and it makes whatever is not similar appear suspicious. In an attack, unity appears as an appeal to membership. A new account presents itself as a member of the recipient's student team and asks for a private participant list for an internal purpose. The appeal leaves both actual membership and access rights to be established.

9.18.7 Scarcity

Scarcity is the tendency to assign more value to things that are rare, dwindling or hard to obtain. In an experiment, students took cookies from a jar. Those from the jar with two cookies chose more than those from the jar with ten, although the cookies were exactly the same. Scarcity can also be symbolic: an attention, a feeling or a reply that seems hard to obtain acquires value. Today this is the person who does not reply, or the typing dots on WhatsApp that leave us wondering whether an answer will come. The principle is linked to a past in which scarcity meant danger, when food, drinkable water, materials for shelter and medicine were scarce. An analogy with sugar illustrates the idea: a resource that was scarce for our ancestors is abundant today. It is an analogy, not evidence, and it is not used here as an argument.

Scarcity appears in marketing as limited offers and countdowns, and in everyday life in the rush to book tickets.

Notes

For example, tickets for a concert, a theatre or a cinema can sell out quickly, and the same pressure appears when a medical appointment is needed for one's health.

In attacks, scarcity shortens the time available for checking. An offer that advertises the last places of a funded training event, and asks for identity documents through an unfamiliar form before the offer expires, raises two different questions: whether the opportunity is really disappearing, and whether the request for documents is legitimate. The analysis must keep them apart.

Scarcity also acts on time and attention. In an analysis, time is often the first resource that is missing, and routine the second: requests are confirmed on autopilot, without checking the number that was already available. Experience does not protect against this: senior people can become negligent, and attention to routine requests drops. Case A shows the same pattern: the request asked for speed and secrecy, and the subsidiary probably had no procedure for such a strange request.

9.19 Summary

The sociological toolbox developed in this chapter can be summarised in the following concepts.

The method follows a simple sequence. First, identify the requests and the records they generate. Second, for each record, reconstruct the context available to the recipient at the time. Third, identify the positions, roles and expectations that give the request its weight. Fourth, check which parts of the explanation are supported by evidence, and which are conjectures. Finally, make the limits of the explanation visible, and say which information would be needed to go further. A good analysis does not claim to know everything; it shows clearly what it knows, what it infers and what it still has to establish.

Concept	Use in the analysis
Request (q)	What is being asked. Different requests are not interchangeable.
Context (C)	What the recipient had available, seen from the recipient's perspective.
Action (a)	The specific action to explain: reply, disclosure, approval or payment.
Record $R = (q, C, a)$	One record per decision; connected records for the whole incident.
Definition of the situation	The activity that the participants understand to be taking place.
Status and role	The rank in a hierarchy and the conduct expected from that rank.
Authority	The tendency to defer to those taken to be knowledgeable or entitled to direct us.
Claimed, actual, attributed	The position presented, the position established afterwards, the position assumed by the recipient.
Empirical and normative expectation	What relevant others do, and what one believes they think ought to be done.
Social norm	A cultural and situated prescription of appropriate conduct.
Reciprocity	The obligation to repay what others have given.
Commitment and consistency	The pressure to act consistently with earlier commitments.
Social proof	The inference drawn from the choices of people whose judgement we respect.
Relevant others (social proof)	The people whose choices a person takes as evidence, selected by the context.
Temperature of a message	The confidentiality, closeness and tone that shape its interpretation.
Cybersecurity (definition)	Organisation of resources, processes and structures protecting cyberspace from misalignments between *de jure* and *de facto* rights.
Epistemic asymmetry	An advantage of knowledge held by one person or group within a specific domain.
Technocratic dominance	The use of technical knowledge to change others' behaviour, reducing their power or authority.
Teleological replacement	The substitution of the victim's goal with the attacker's goal.
Epistemic backstop	Recordings that regulate testimonial practices.
Starting explanation	The first account, written from the first reading and revised as the analysis develops.
Three stages of the method	Fact-gathering, analysis of findings, and recommendations last.
Gap between account and evidence	A guide to further work: which document, person or record would change the explanation.
Liking, unity, scarcity	Cialdini's principles: attraction to people we like, identification with a group, and value given to what is scarce.
Regulatory function	The effect that the existence of a recording has on behaviour, even when it is not consulted.
Evidence and proposition	The record that represents a claim, kept separate from the claim itself.
Mandate	The scope of what a genuine role is entitled to request.
H1, H2, $T(m, d)$	The executed destination, the instructed destination, and the executed transfer as a function of amount and destination.

Table 9.1: Concepts of the sociological toolbox for social engineering.

Part III

Exercises without solutions

Part IV

Exercises